MODULE – 4

Cloud Security

atatus

Cloud Computing Software Security Fundamentals

Subtitle:-Cloud Information Security Objectives

What is Cloud Security?

PROTECTS DATA STORED IN CLOUD COMPUTING ENVIRONMENTS FROM THEFT, DELETION & LEAKAGE.

PROTECTIVE METHODS INCLUDE:

- Access Control
- Firewalls
- Penetration Testing
- Obfuscation
- Virtual Private Networks (VPNs)
- Not Using Public Internet Connections
- Tokenization

Cloud Information Security Objectives

- Developing secure software is based on applying the secure software design principles that form the fundamental basis for software assurance.
- Software assurance has been given many definitions, and it is important to understand the concept.
- The Software Security Assurance Report defines software assurance as “the basis for gaining justifiable confidence that software will consistently exhibit all properties required to ensure that the software, in operation, will continue to operate dependably despite the presence of sponsored (intentional) faults.
- The U.S. Department of Defense (DoD) Software Assurance Initiative3 defines software assurance as “the level of confidence that software functions as intended and is free of vulnerabilities, either intentionally or unintentionally designed or inserted as part of the software.”

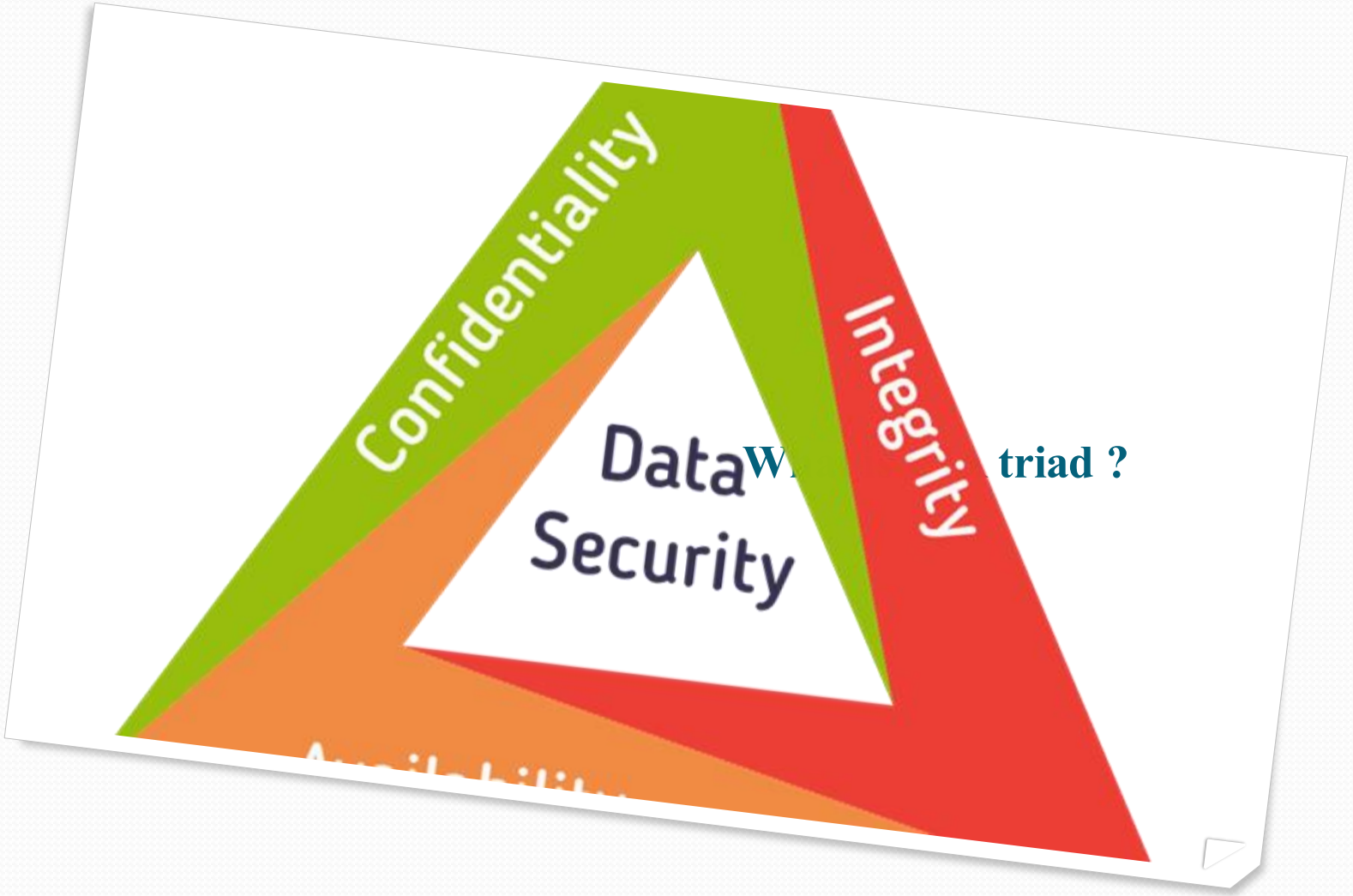
The Data and Analysis Center for Software (DACS) requires that software must exhibit the following three properties to be considered secure:

- Dependability — Software that executes predictably and operates correctly under a variety of conditions, including when under attack or running on a malicious host
- Trustworthiness — Software that contains a minimum number of vulnerabilities or no vulnerabilities or weaknesses that could sabotage the software's dependability. It must also be resistant to malicious logic.
- Survivability (Resilience) — Software that is resistant to or tolerant of attacks and has the ability to recover as quickly as possible with as little harm as possible

Seven complementary principles that support information assurance are confidentiality, integrity, availability, authentication, authorization, auditing, and accountability. These concepts are summarized in the following sections.

Confidentiality, Integrity, and Availability

- Confidentiality, integrity, and availability are sometimes known as the CIA triad of information system security, and are important pillars of cloud software assurance.



W triad ?

Confidentiality:

Confidentiality refers to the prevention of intentional or unintentional unauthorized disclosure of information

Intellectual property rights

Covert channels

Traffic analysis

Encryption

Inference

Integrity

The concept of cloud information integrity requires that the following three principles are met:

Availability

RELEVANT CLOUD SECURITY DESIGN PRINCIPLES

INTRODUCTION

With the rise in malicious attacks on information systems, security has become a fundamental aspect of software design. Modern methodologies in cloud computing prioritize security alongside cost, performance, reliability, and maintainability objectives. Balancing security with functionality is essential, as absolute security may impact performance. Hackers with sufficient resources can exploit vulnerabilities. The objective is to achieve everyday usability while ensuring reasonable performance and reliability. The enduring relevance of Saltzer and Schroeder's 1974 paper underscores the significance of hardware and software considerations in information protection.

CLOUD SECURITY DESIGN PRINCIPLES

The 1974 paper by Saltzer and Schroeder presented the following 11 security design principles:

- **Least privilege**
- **Separation of duties**
- **Defense in depth**
- **Fail safe**
- **Economy of mechanism**

CLOUD SECURITY DESIGN PRINCIPLES

- **Complete mediation**
- **Open design**
- **Least common mechanism**
- **Psychological acceptability**
- **Weakest link**
- **Leveraging existing components**

LEAST PRIVILEGE

The principle of least privilege is a fundamental cloud security design principle that aims to limit access to only the necessary privileges and resources for individuals, processes, or entities to fulfill their specific tasks. By following this principle, organizations can significantly reduce the risk of unauthorized access to sensitive information. It ensures that users and systems are granted only the minimum privileges required for their immediate needs and for the shortest duration necessary, thereby minimizing the potential attack surface and mitigating the impact of potential security breaches. Implementing the principle of least privilege strengthens overall security posture and enhances data confidentiality and integrity within cloud environments.

SEPARATION OF DUTIES

Separation of duties is a critical principle in cloud security design that ensures accountability and mitigates the risk of unauthorized access or compromise. It operates on the premise that completing a sensitive activity or gaining access to sensitive objects should be contingent upon satisfying multiple conditions. For instance, an authorization process might mandate the signatures of more than one individual, or the arming of a weapons system could necessitate the collaboration of two individuals possessing distinct keys. By implementing separation of duties, the system enforces a level of checks and balances that requires collusion among entities to undermine its security measures.

SEPARATION OF DUTIES

This principle serves as a safeguard against internal threats and malicious activities by introducing complexity and reducing the likelihood of a single point of failure. It acts as a deterrent against unauthorized actions, as it becomes more difficult for an individual to carry out nefarious activities without the involvement or collusion of others. Additionally, separation of duties enhances transparency and accountability within an organization, as multiple parties are involved in critical processes, ensuring a shared responsibility for security and reducing the potential for abuse of privileges. By adhering to the principle of separation of duties, cloud systems can establish an additional layer of protection, mitigating risks and fortifying their overall security posture.

DEFENSE IN DEPTH

Defense in depth is a crucial concept in ensuring robust cloud security, employing multiple layers of protection to mitigate risks. The "Information Assurance Technical Framework" (IATF) by the Information Assurance Technical Framework Forum (IATFF), sponsored by the National Security Agency (NSA), offers valuable guidance on defense in depth. The IATFF facilitates exchanges on information assurance among U.S. industry, academic institutions, and government agencies. More information about the IATFF document can be found at www.niap-ccevs.org/cc-scheme/IATF_3.1-Chapter_03-ISSEP.pdf. In line with the IATF document, it highlights the importance of people, operations, and technology in achieving information assurance and organizational mission.

DEFENSE IN DEPTH

The IATF document 3.16 emphasizes the following principles for implementing defense in depth:

- **Defense in multiple places: Implement information protection mechanisms in various locations to safeguard against internal and external threats.**
- **Layered defenses: Employ multiple protection and detection mechanisms to create barriers that adversaries must overcome to access critical information.**
- **Security robustness: Assess the strength of information assurance elements based on the value of the system component being protected and the anticipated threats.**

DEFENSE IN DEPTH

- **Deploy KMI/PKI: Utilize robust key management infrastructures (KMI) and public key infrastructures (PKI) to enhance security.**
- **Deploy intrusion detection systems: Implement intrusion detection mechanisms to identify and evaluate intrusions, analyze information, and take necessary action.**

FAIL SAFE

Fail safe means that if a cloud system fails it should fail to a state in which the security of the system and its data are not compromised. One implementation of this philosophy would be to make a system default to a state in which a user or process is denied access to the system. A complementary rule would be to ensure that when the system recovers, it should recover to a secure state and not permit unauthorized access to sensitive information. This approach is based on using permissions instead of exclusions. In the situation where system recovery is not done automatically, the failed system should permit access only by the system administrator and not by other users, until security controls are reestablished.

FAIL SAFE

In scenarios where automatic system recovery is not feasible, it is essential for the failed system to restrict access solely to the system administrator. Other users should be temporarily denied access until security controls are reestablished. This precautionary measure minimizes the risk of unauthorized access and maintains the integrity of the system and its data during the recovery process.

ECONOMY OF MECHANISM

One essential principle in cloud security design is the economy of mechanism, which advocates for simple and easily understandable protection mechanisms. By adopting this principle, organizations can ensure that their cloud systems are designed and implemented in a straightforward manner, minimizing the potential for unintended access paths. This approach enables quick identification and elimination of any vulnerabilities or weaknesses in the system. Emphasizing simplicity and comprehensibility in security mechanisms enhances overall system security and reduces the likelihood of unauthorized access or exploitation of system flaws.

COMPLETE MEDIATION

In a secure computer system, complete mediation ensures that every access request from a subject to an object undergoes a thorough and effective authorization process. This mediation remains active and cannot be suspended or bypassed, even during system initialization, shutdown, restart, or maintenance activities. The concept of complete mediation encompasses several essential elements:

- **Identification: It is crucial to accurately identify the entity making the access request. This involves validating the identity of the subject seeking access to the object.**

COMPLETE MEDIATION

- **Request Integrity: The system must verify that the access request has not been tampered with or modified since its initiation. Ensuring the integrity of the request is essential to maintain the trustworthiness of the authorization process.**
- **Authorization Procedures: Appropriate and robust authorization procedures should be applied to determine whether the subject is permitted to access the requested object. This involves evaluating the subject's permissions and privileges within the system.**

OPEN DESIGN

The debate between secret security designs and open ones has long existed, with encryption systems being a prime example. Some argue that keeping the encryption algorithm secret adds difficulty to breaking it, while others believe that exposing it for evaluation by experts leads to stronger algorithms. Generally, the latter approach has proven more effective, except in cases involving organizations like the NSA, which boasts exceptional cryptographers. For most purposes, an open-access cloud system design that undergoes extensive evaluation offers more secure authentication methods, with the security relying on protecting passwords or keys.

LEAST COMMON MECHANISM

The principle of least common mechanism suggests that minimizing shared access paths among multiple users reduces the risk of unauthorized information exchange through covert channels. Covert channels refer to unintentional data transfers. By limiting the sharing of common security mechanisms, this principle aims to minimize the potential for data leakage or unauthorized access.

PSYCHOLOGICAL ACCEPTABILITY

Psychological acceptability in cloud access control mechanisms relates to the user interface's ease of use and intuitiveness. It is essential for users to comprehend and navigate the interface without the need for complex instructions or interpretation. The user interface should be designed to promote simplicity and user-friendliness, ensuring a seamless and intuitive user experience.

WEAKEST LINK

The strength of a cloud system's security is inherently dependent on its weakest component, much like the analogy "A chain is only as strong as its weakest link." Therefore, it becomes crucial to identify and enhance the weakest mechanisms and layers of defense within the security chain. This proactive approach ensures that risks to the system are effectively mitigated to a level deemed acceptable.

LEVERAGING EXISTING COMPONENTS

In many cases, cloud implementations suffer from inadequate configuration and underutilization of security mechanisms. By conducting a thorough review of existing security mechanisms and optimizing their settings, the overall security posture of an information system can be significantly enhanced. Another effective strategy to bolster cloud system security is to partition the system into separate defended subunits. This ensures that if one subunit is compromised, the impact is contained, minimizing damage to computing resources and other subunits. By leveraging these approaches, organizations can strengthen the security of their cloud systems and protect against potential threats.

Secure Cloud Software Requirements

It must be dependable under anticipated operating conditions, and remain dependable under hostile operating conditions.

It must be trustworthy in its own behavior, and in its inability to be compromised by an attacker through exploitation of vulnerabilities or insertion of malicious code.

It must be resilient enough to recover quickly to full operational capability with a minimum of damage to itself, the resources and data it handles, and the external components with which it interacts

Secure Development Practices

Handling data — Some data is more sensitive and requires special handling.

Code practices — Care must be taken not to expose too much information to a would-be attacker.

Language options — Consider the strengths and weakness of the language used.

Input validation and content injection — Data (content) entered by a user should never have direct access to a command or a query.

Physical security of the system — Physical access to the cloud servers should be restricted.

Approaches to Cloud Software Requirements Engineering

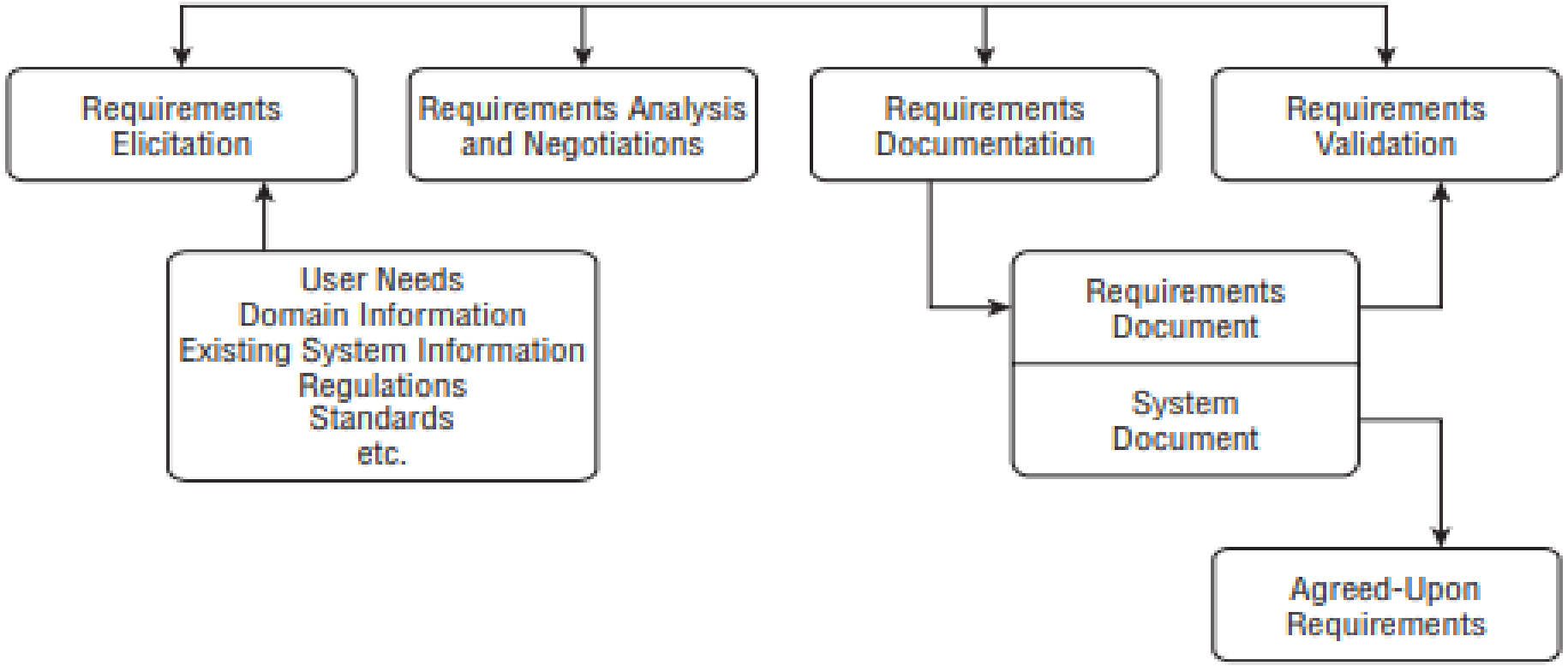


Figure 3-1: Software requirements engineering components

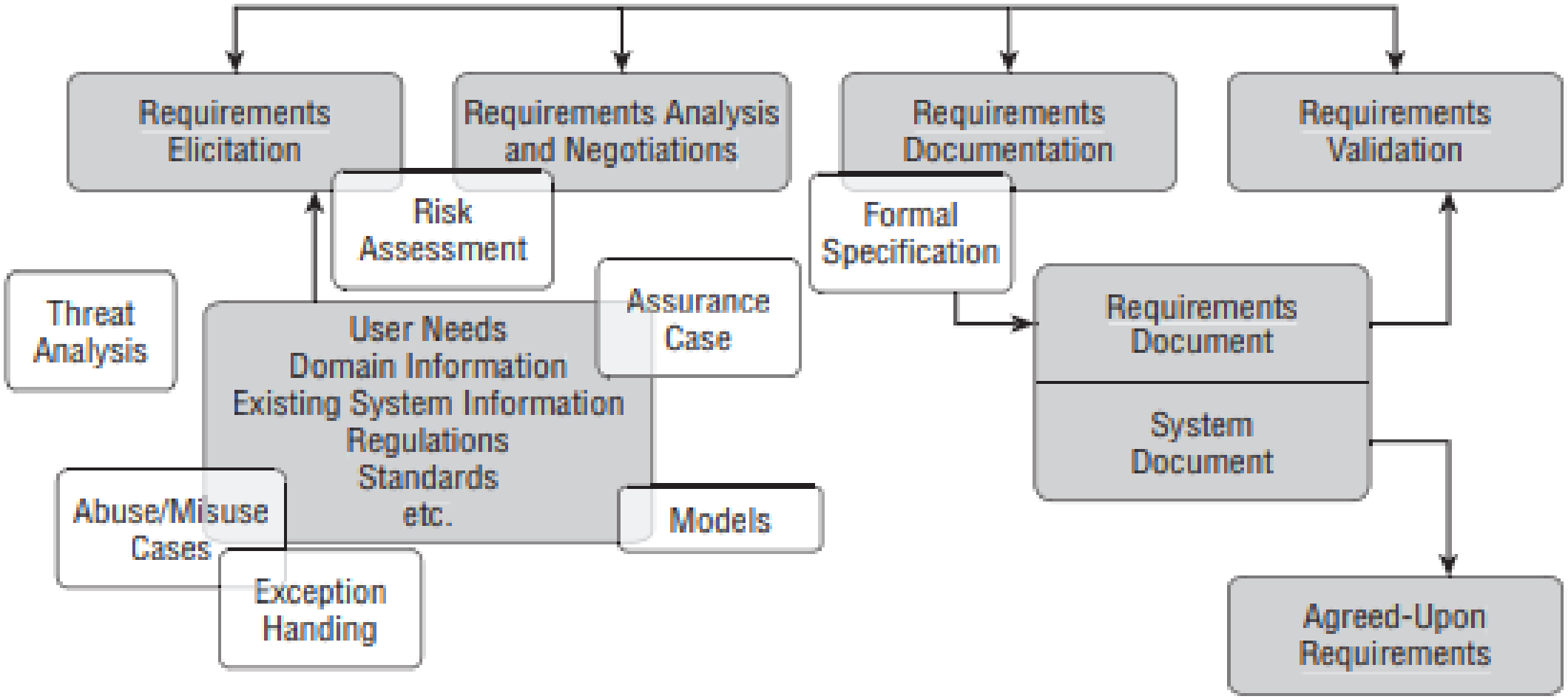


Figure 3-2: Additions to the software requirements engineering process to promote secure software

A Resource Perspective on Cloud Software Security Requirements

 Specific — The requirement should be unambiguous and direct. Mannion and Keepence defi ne this characteristic as being clear, consistent, and simple.
 Measurable — The requirement should be measurable to ensure that it has been met.
 Attainable — The system must be able to exhibit the requirement under the specifi ed conditions.
 Realizable — The requirement must be achievable under the system and project development constraints.
 Traceable — The requirement should be traceable both forward and backward throughout the development life cycle from conception through design, implementation, and test.

Goal-Oriented Software Security Requirements

- Properties the software must exhibit (e.g., its behavior must be correct and predictable; it must remain resilient in the face of attacks)
- Required level of assurance or risk-avoidance of individual security functions and constraints
- Controls and rules governing the processes by which the software will be built, deployed, and operated (e.g., it must be designed to operate within a virtual machine, and its source code must not contain certain function calls)

Cloud software security requirements address necessary attributes for software behavior and limitations on software functionality, whereas cloud software requirements are concerned with necessary software functionality and performance specifications.

Monitoring Internal and External Requirements

The requirements of the information system security policy relative to software assurance should be analyzed to ensure their consistency and correctness. Two types of secure software requirements analysis should be performed:

- Internal — Necessary in order to ascertain that the requirements are complete, correct, and consistent with the related specification requirements. The analysis should address the following:
- Security constraints
- The software's nonfunctional properties
- The software's positive functional requirements

External

Necessary to determine the following:

- The software assurance requirements address the legal regulatory and required policy issues.
- The nonfunctional security requirements represent a proper decomposition of the system security goals.
- Software assurance requirements don’t conflict with system security goals.
- The software is resilient.

Table 3-1: Internal and External Security Requirements

INTERNAL	EXTERNAL
Maintain identity of active users	External connections must incorporate adequate controls to safeguard IT resources.
Implement internal access controls	At a minimum, all external connections must incorporate a firewall.
Use secure gateways to allow internal users to connect to external networks	If the user access originates from outside the protected network, user must be identified and authenticated at the gateway.
Hide internal Domain Name Systems (DNSs)	Use external authentication databases, such as RADIUS.
Dial-up modems should not be connected to computers that are connected to the internal network.	Employ content filtering to permit or deny services to specific external hosts.
E-mail messages flowing through the information systems should be monitored for internal policy compliance.	Accredit external connections prior to use.
	External connections should be periodically reviewed by an independent organization.

Cloud Security Policy Implementation and Decomposition

Implementation Issues Important areas addressed by a software system's cloud security policy include the following:

- Access controls
- Data protection
- Confidentiality
- Integrity
- Identification and authentication
- Communication security
- Accountability

Decomposing Critical Security Issues into Secure Cloud Software Requirements

1. Confidentiality
2. Integrity
3. Availability
4. Authentication and Identification
5. Authorization
6. Auditing

the ISACA introduced a valuable audit planning and execution tool, the “Control Objectives for Information and Related Technology (COBIT)” document. COBIT defines a *control objective that is a goal aimed at preventing a set of risks from occurring* . *The* four COBIT domains are as follows:

1. Planning and organization (PO) — Provides direction to solution delivery (AI) and service delivery (DS)
2. Acquisition and implementation (AI) — Provides the solutions and passes them to be turned into services
3. Deliver and support (DS) — Receives the solutions and makes them available for end users
4. Monitor and evaluate (ME) — Monitors all processes to ensure that the direction provided is followed

NIST 33 Security Principles

The National Institute of Standards and Technology's Information Technology Laboratory (ITL) published security principles. Some of the 33 principles that are most applicable to cloud security policies and management are as follows:

- Principle 1 — Establish a sound security policy as the "foundation" for design.

- Principle 2 — Treat security as an integral part of the overall system design.

- Principle 3 — Clearly delineate the physical and logical security boundaries governed by associated security policies.

- Principle 6 — Assume that external systems are insecure.

- Principle 7 — Identify potential trade-offs between reducing risk and increased costs and decreases in other aspects of operational effectiveness.
- Principle 16 — Implement layered security; ensure there is no single point of vulnerability.
- Principle 20 — Isolate public access systems from mission-critical resources (e.g., data, processes, etc.).
- Principle 21 — Use boundary mechanisms to separate computing systems and network infrastructures.
- Principle 25 — Minimize the system elements to be trusted.
- Principle 26 — Implement least privilege.
- Principle 32 — Authenticate users and processes to ensure appropriate access control decisions both within and across domains.
- Principle 33 — Use unique identities to ensure accountability.

Secure Cloud Software Testing

Secure cloud software testing involves a number of activities. Each activity is based on a formal standard or methodology and adds unique value to the overall secure software testing process. An organization typically selects testing activities based on a number of factors, including secure cloud software requirements and available resources.

Types of Testing

1. Conformance Testing
2. ***Functional Testing***
3. ***Performance Testing***
4. ***Security Testing***
5. **Interoperability Testing**

Cloud Penetration Testing

A penetration test is a security testing methodology that gives the tester insight into the strength of the target's network security by simulating an attack from a malicious source. The process involves an active analysis of the cloud system for any potential vulnerabilities that may result from poor or improper system configuration, known and/or unknown hardware or software flaws, or operational weaknesses in process or technical countermeasures. This analysis is carried out from the position of a potential attacker, and can involve active exploitation of security vulnerabilities.

The intent of a penetration test is to proactively determine the feasibility of an attack or to retroactively determine the degree to which a successful exploit has affected the business. It is a component of a full security audit, which includes the following:

- **A Level I, high-level assessment** — A top-down look at the organization's policies, procedures, standards, and guidelines. A Level I assessment is not usually hands-on, in that the system's security is not actually tested.
- **A Level II, network evaluation** — More hands-on than a Level I assessment, a Level II assessment has some of the Level I activities plus more information gathering and scanning.
- **A Level III, penetration test** — A penetration test is not usually concerned with policies. It is more about taking the adversarial view of a hacker, by seeing what can be accomplished, and with what difficulty.

Penetration testing is most commonly carried out within a “black box,” that is, with no prior knowledge of the infrastructure to be tested. At its simplest level, the penetration test involves three phases:

1. **Preparation** — A formal contract is executed containing nondisclosure of the client’s data and legal protection for the tester. At a minimum, it also lists the IP addresses to be tested and the time to test.
2. **Execution** — In this phase the penetration test is executed, with the tester looking for potential vulnerabilities.
3. **Delivery** — The results of the evaluation are communicated to the tester’s contact in the organization, and corrective action is advised.

Password Crackers

Password cracking doesn’t have to involve fancy tools, but it is a fairly tedious process. If the target doesn’t lock you out after a specific number of tries, you can spend an infinite amount of time trying every combination of alphanumeric characters. It’s just a question of time and bandwidth before you break into the system.

Three basic types of password cracking methods can be automated with tools:

1. Dictionary — A file of words is run against user accounts. If the password is a simple word, it can be found fairly quickly.

2. Hybrid — A hybrid attack works like a dictionary attack, but adds simple numbers or symbols to the file of words. This attack exploits a weakness of many passwords: they are common words with numbers or symbols tacked on the end.

3. Brute force — The most time-consuming but comprehensive way to crack a password. Every combination of character is tried until the password is broken.

Security Policy Implementation

Security policies are the foundation of a sound security implementation. Often organizations will implement technical security solutions without first creating this foundation of policies, standards, guidelines, and procedures, unintentionally creating unfocused and ineffective security controls.

A *policy is one of those terms that can mean several things. For example, there* are security policies on firewalls, which refer to the access control and routing list information. Standards, procedures, and guidelines are also referred to as policies in the larger sense of a global information security policy.

Figure shows how the policies relate to each other hierarchically.

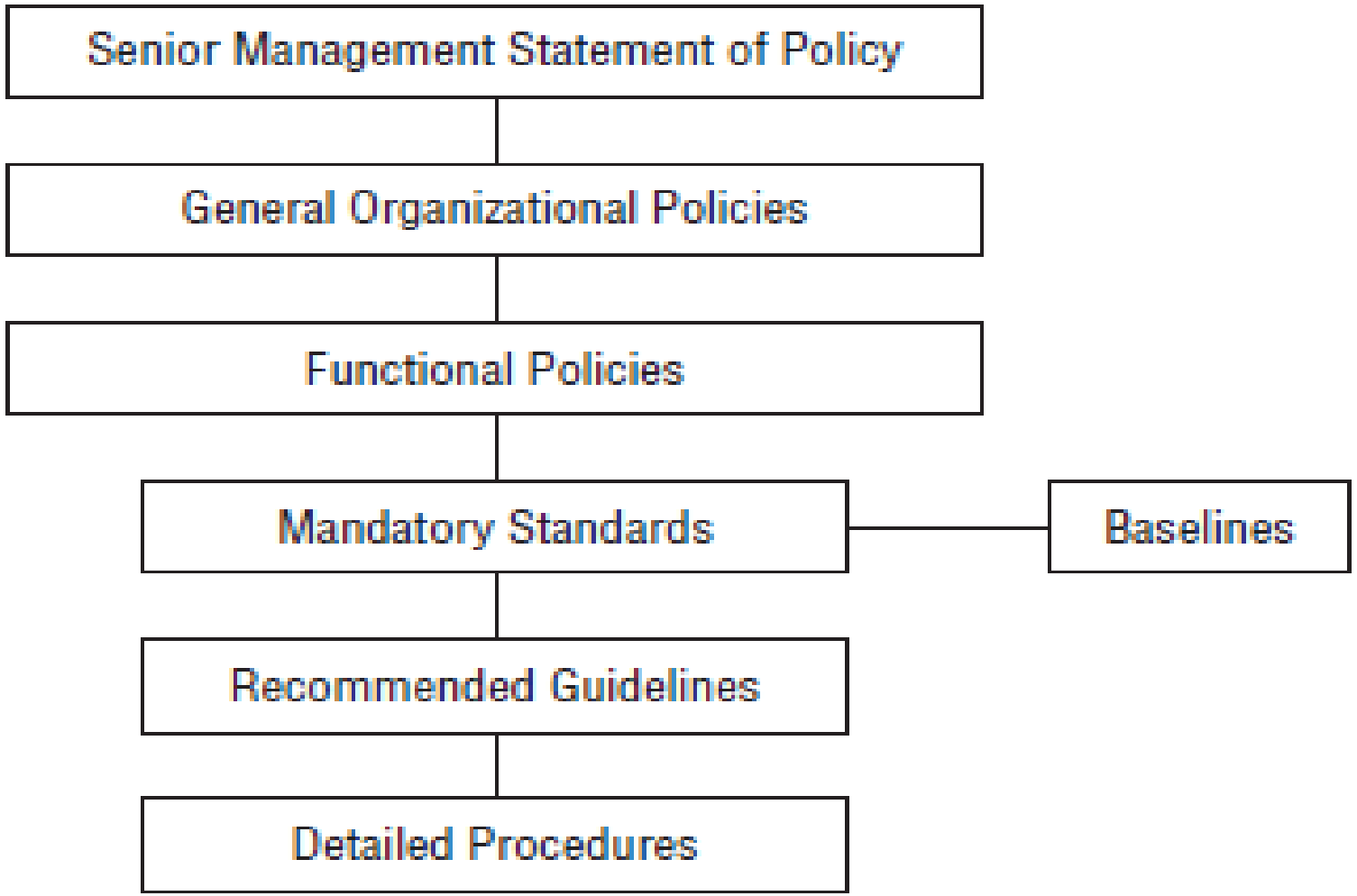


Figure 5-1: Security policy hierarchy

Computer Security Incident Response Team (CSIRT)

As part of a structured incident-handling program of intrusion detection and response, a Computer Emergency Response Team (CERT) or computer security incident response team (CSIRT) is commonly created.

The main tasks of a CSIRT are as follows:

- Analysis of an event notification
- Response to an incident if the analysis warrants it
- Escalation path procedures
- Resolution, post-incident follow-up, and reporting to the appropriate parties

The prime directive of every CIRT is incident response management, which reflects a company's response to events that pose a risk to its computing environment.

This management often consists of the following:

- Coordinating the notification and distribution of information pertaining to the incident to the appropriate parties (those with a need to know) through a predefined escalation path
- Mitigating risk to the enterprise by minimizing the disruptions to normal business activities and the costs associated with remediating the incident (including public relations)
- Assembling teams of technical personnel to investigate the potential vulnerabilities and resolve specific intrusions

Additional examples of CIRT activities are:

- Management of the network logs, including collection, retention, review, and analysis of data
- Management of an incident's resolution, management of a vulnerability's remediation, and post-event reporting to the appropriate parties

Virtualization Security Management

VIRTUALIZATION TYPES

The Virtual Machine (VM), Virtual Memory Manager (VMM), and hypervisor or host OS are the minimum set of components needed in a virtual environment.

They comprise virtual environments in a few distinct ways:

- Type 1 virtual environments are considered “full virtualization” environments and have VMs running on a hypervisor that interacts with the hardware.
- Type 2 virtual environments are also considered “full virtualization” but work with a host OS instead of a hypervisor.
- Para-virtualized environments offer performance gains by eliminating some of the emulation that occurs in full virtualization environments.
- Other type designations include hybrid virtual machines (HVMs) and hardware-assisted techniques.

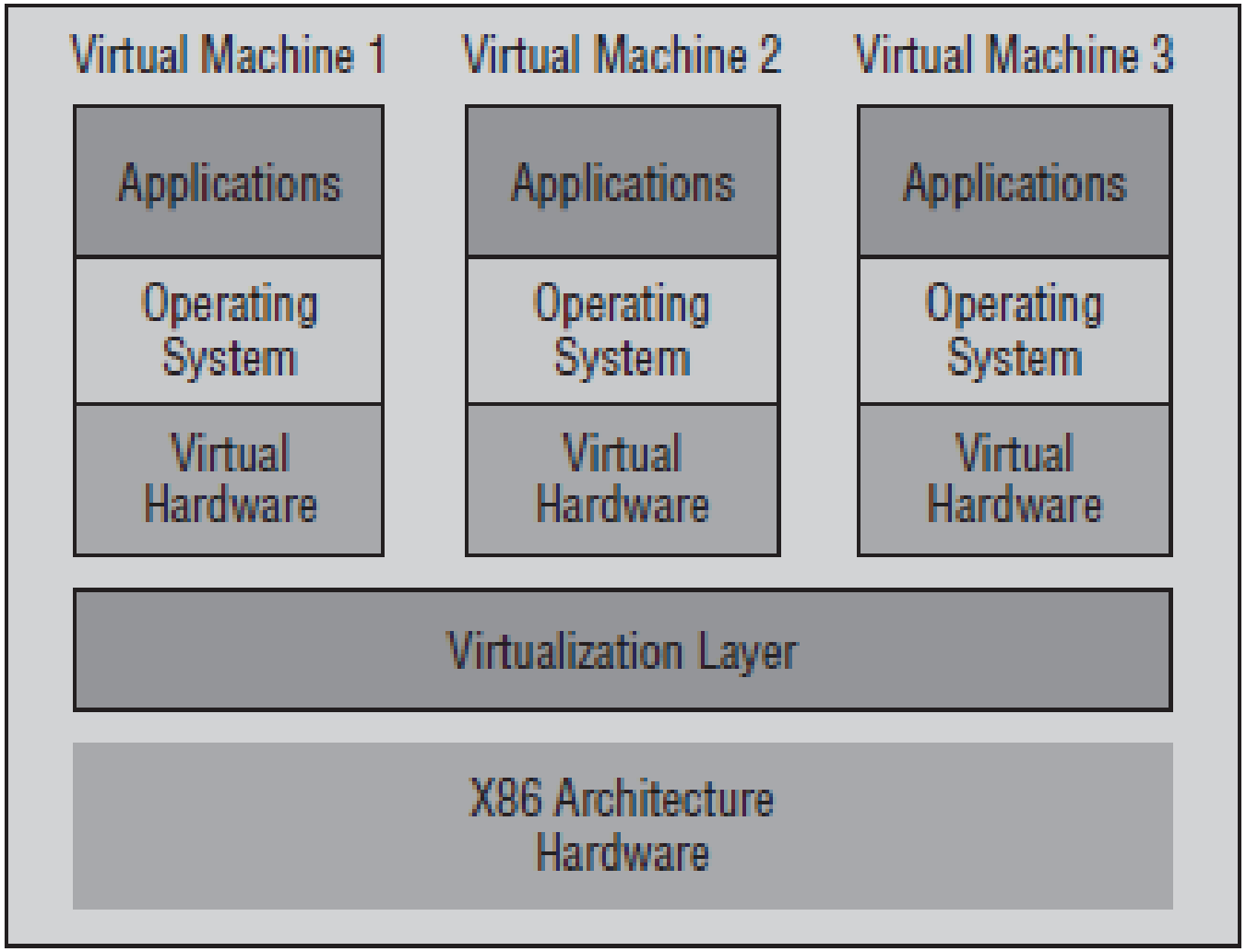


Figure 5-2: Type 1 virtualized environment

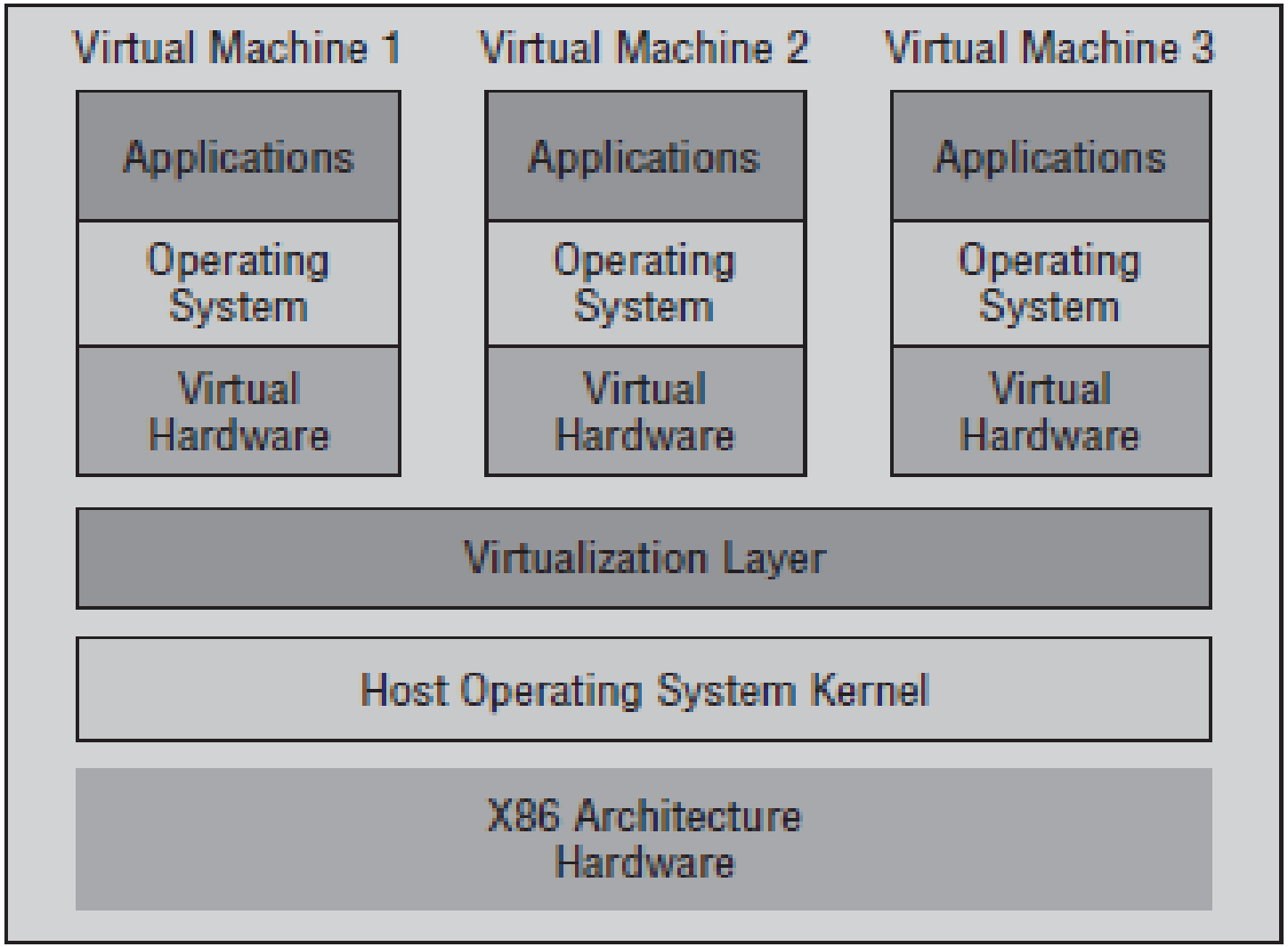


Figure 5-3: Type 2 virtualized environment

VIRTUALIZATION MANAGEMENT ROLES

Typically, the VMware Infrastructure is managed by several users performing different roles. The roles assumed by administrators are the Virtualization Server Administrator, Virtual Machine Administrator, and Guest Administrator.

 Virtual Server Administrator — This role is responsible for installing and configuring the ESX Server hardware, storage, physical and virtual networks,
service console, and management applications.

 Virtual Machine Administrator — This role is responsible for creating and configuring virtual machines, virtual networks, virtual machine resources, and security policies. The Virtual Machine Administrator creates, maintains, and provisions virtual machines.

 Guest Administrator — This role is responsible for managing a guest virtual machine or machines. Tasks typically performed by Guest Administrators include connecting virtual devices, adding system updates, and managing applications that may reside on the operating

VM-Specific Security Techniques

1. Hardening the Virtual Machine
2. Harden the Hypervisor
3. Root Secure the Monitor
4. Implement Only One Primary Function per VM
5. Firewall Any Additional VM Ports
6. Harden the Host Domain
7. Use Unique NICs for Sensitive VMs
8. Disconnect Unused Devices
9. Additional VM Recommendations